

UNIVERSITÉ MOHAMMED VI POLYTECHNIQUE

Projet Professionnel — Cahier des Charges

CyberSentinel AI

Plateforme Intelligente de Détection des Cyberattaques et de Réponse Assistée par IA

Rédigé par : HARKI Anasse

Élève-ingénieur — Cycle Ingénieur Informatique, IA et Confiance Numérique — ENSA Fès

Juillet 2026

1. Contexte et présentation générale

Les organisations — campus universitaires comme entreprises — génèrent quotidiennement des volumes massifs de journaux d'événements (logs) issus de systèmes hétérogènes : postes Windows, serveurs Linux, pare-feux, sondes IDS/IPS, passerelles VPN. Les équipes SOC (Security Operations Center), souvent en sous-effectif, ne peuvent traiter manuellement ce flux en temps réel, ce qui retarde la détection des incidents et augmente le risque d'impact.

CyberSentinel AI est une plateforme de cybersécurité augmentée par l'intelligence artificielle, capable de collecter, analyser, classer et expliquer les événements de sécurité, puis d'assister l'analyste via un agent conversationnel génératif (GenAI SOC Assistant).

Avertissement de portée : pour des raisons d'autorisation et de sécurité, le projet n'analyse à aucun moment le réseau réel de l'UM6P. Il s'appuie sur des jeux de données publics reconnus (CICIDS2017/2018, NSL-KDD, UNSW-NB15, LogHub) et sur un environnement de laboratoire virtualisé reproduisant fidèlement le fonctionnement d'un SOC. L'architecture logicielle reste toutefois conçue selon des standards ouverts (Syslog, ECS, STIX/TAXII) afin d'être raccordable ultérieurement à des équipements réels (pare-feu, IDS/IPS, SIEM, serveurs de logs).

2. Problématique

Comment concevoir un système capable de détecter automatiquement des cyberattaques variées (brute force, malware, ransomware, DDoS, menace interne) à partir de logs multi-sources, de hiérarchiser les alertes selon leur criticité réelle, d'expliquer ses décisions de façon compréhensible pour un analyste non-expert en IA, et d'accélérer la réponse à incident grâce à un assistant génératif contextualisé ?

3. Objectifs du projet

3.1 Objectif général

Concevoir et développer une plateforme intelligente, modulaire et déployable en conteneurs, capable de simuler les fonctions clés d'un SOC moderne : ingestion de logs, détection par IA, priorisation, contextualisation via threat intelligence, assistance générative et supervision via tableau de bord.

3.2 Objectifs spécifiques

- Mettre en place un pipeline d'ingestion et de normalisation de logs multi-sources (Windows, Linux, Firewall, IDS, VPN).
- Entraîner des modèles de Machine Learning capables de détecter 5 familles d'attaques (brute force, malware, ransomware, DDoS, insider threat).
- Développer un moteur de scoring/classification à 4 niveaux de criticité (Critical / High / Medium / Low).
- Intégrer une couche d'explicabilité (XAI) pour justifier chaque alerte auprès de l'analyste.
- Enrichir automatiquement les alertes via des bases de threat intelligence publiques (MITRE ATT&CK, CVE/NVD).
- Développer un assistant SOC basé sur un LLM avec RAG (Retrieval-Augmented Generation) pour l'explication, la remédiation et le reporting.
- Construire un tableau de bord temps réel avec cartographie des attaques, alertes et KPIs.
- Conteneuriser et automatiser le déploiement (CI/CD, Docker, Kubernetes) sur AWS avec supervision Prometheus/Grafana.

4. Périmètre du projet

Inclus dans le périmètre	Exclu du périmètre
Environnement de laboratoire simulé / datasets publics	Connexion au réseau réel de l'UM6P
Détection de 5 familles d'attaques prioritaires	Couverture exhaustive de toutes les techniques MITRE ATT&CK
Dashboard web avec KPIs et carte des attaques	Application mobile native
Assistant GenAI en lecture/analyse/reporting	Remédiation automatique (auto-response) sans validation humaine
Déploiement Docker/Kubernetes sur environnement de test AWS	Mise en production sur infrastructure UM6P réelle

5. Architecture globale du système

L'architecture est organisée en 7 couches indépendantes et communiquant via API REST / message broker, permettant une évolutivité modulaire :

- Couche 1 — Collecte : agents de collecte et normalisation des logs.
- Couche 2 — Stockage : base de données d'événements et data lake.
- Couche 3 — Détection IA : modèles ML/DL de classification des menaces.
- Couche 4 — Enrichissement : corrélation avec le threat intelligence externe.
- Couche 5 — Explicabilité (XAI) : génération des justifications d'alerte.
- Couche 6 — GenAI Assistant : agent conversationnel RAG pour le SOC.
- Couche 7 — Présentation : dashboard web, API backend, notifications temps réel.

Flux de données simplifié : Sources de logs → Agents de collecte (Filebeat/Winlogbeat/Wazuh) → Bus de messages (Kafka/Redis Streams) → Moteur de normalisation (ECS) → Stockage (Elasticsearch) → Pipeline IA (détection + scoring + XAI) → Enrichissement Threat Intel → Base de données des alertes (PostgreSQL) → API backend (.NET Core / FastAPI) → Dashboard (Blazor + Grafana) & Assistant GenAI.

6. Spécifications fonctionnelles et techniques par module

6.1 Module Collecte de logs

Rôle : capter et normaliser les événements provenant des différentes sources hétérogènes du SOC.

Source	Agent / Outil retenu	Format de sortie
Logs Windows (Sécurité, Sysmon)	Winlogbeat + Sysmon	JSON — schéma ECS
Logs Linux (syslog, auth.log)	Filebeat	JSON — schéma ECS
Logs Firewall	pfSense / iptables + Logstash	JSON normalisé
Logs IDS/IPS	Suricata (règles Emerging Threats)	EVE JSON
Logs VPN	OpenVPN + Filebeat	JSON normalisé

Environnement de simulation : un laboratoire virtualisé (Docker Compose / VirtualBox) reproduisant un mini-SOC — VM Windows + VM Linux + Suricata + pfSense — dans lequel des attaques contrôlées (Hydra pour brute force, hping3/LOIC pour DDoS, échantillons malware sandboxés) génèrent des logs réalistes, complétés par les datasets publics CICIDS2017/2018, NSL-KDD, UNSW-NB15 et LogHub.

6.2 Module AI Detection

Approche hybride combinant règles de détection (signatures Suricata/Sigma) et modèles de Machine Learning supervisés, en réutilisant les compétences en data science déjà mobilisées sur vos projets académiques (scoring hybride, NLP financier).

Type d'attaque	Approche IA retenue	Technologies
Brute force	Classification supervisée sur features comportementales (nb. tentatives, fenêtre temporelle, IP source)	XGBoost, scikit-learn
Malware	Classification à partir de représentation binaire convertie en image (technique « malware-as-image »)	OpenCV (prétraitement), CNN léger (PyTorch/TensorFlow)
Ransomware	Détection comportementale (accès fichiers massifs, chiffrement, extension suspecte)	XGBoost + règles heuristiques Sigma
DDoS	Analyse de flux réseau (NetFlow) et détection d'anomalies statistiques	XGBoost, Isolation Forest
Insider threat (UEBA)	Analyse comportementale utilisateur, détection d'anomalies non supervisée	Isolation Forest, KMeans, Autoencoder

Gestion du déséquilibre des classes (attaques rares) via SMOTE / class-weighting. Entraînement et validation croisée avec métriques précision/rappel/F1 adaptées aux classes minoritaires.

6.3 Module Classification (scoring de criticité)

Un score composite (0 à 100) est calculé à partir de trois facteurs : la confiance du modèle ML, la criticité de l'actif touché et la sévérité CVE associée — logique directement inspirée du système hybride de scoring de crédit combinant base transactionnelle et règles métier. Le score est ensuite discrétisé en 4 niveaux :

Niveau	Plage de score	Action déclenchée
Critical	80 – 100	Alerte immédiate + notification GenAI + escalade
High	60 – 79	Alerte prioritaire dans le dashboard
Medium	35 – 59	Ajout à la file de supervision
Low	0 – 34	Archivage / log passif

6.4 Module Explainable AI (XAI)

Chaque alerte critique doit être justifiée pour être exploitable par un analyste. Le module génère une explication basée sur les variables les plus influentes du modèle.

- SHAP (SHapley Additive exPlanations) pour les modèles XGBoost — importance globale et locale des features.
- LIME en complément pour les modèles boîte noire (CNN malware).
- Génération automatique d'un résumé textuel des 3 à 5 variables déterminantes, transmis ensuite au GenAI SOC Assistant pour vulgarisation en langage naturel.

6.5 Module Threat Intelligence

Enrichissement automatique de chaque alerte avec le contexte de menace correspondant, via un micro-service d'agrégation.

Source	Intégration technique	Donnée récupérée
MITRE ATT&CK	Librairie mitreattack-python + flux STIX/TAXII	Tactique, technique, sous-technique associée
CVE	API NVD REST 2.0	Détail de la vulnérabilité exploitée

Source	Intégration technique	Donnée récupérée
NVD (scores)	API NVD + cache local	Score CVSS, sévérité, exploitabilité

Micro-service développé en Python (FastAPI), avec un cache Redis pour limiter les appels API externes et garantir la performance en environnement de démonstration.

6.6 Module GenAI SOC Assistant

Un agent conversationnel basé sur un LLM (API Claude ou GPT), utilisant une architecture RAG similaire à celle déjà développée lors de la compétition GENIA-V1 (chatbot documentaire pour réseaux informatiques), mais appliquée ici aux données de sécurité.

- Base documentaire vectorisée : techniques MITRE ATT&CK, fiches CVE, playbooks de remédiation, historique des incidents.
- Base vectorielle : ChromaDB ou FAISS, embeddings via un modèle open-source (sentence-transformers) ou l'API du fournisseur LLM.
- Fonctions supportées : « Explique cette attaque », « Donne les actions de remédiation », « Génère un rapport SOC », « Résume les incidents de la journée ».
- Garde-fous : réponses strictement fondées sur le contexte récupéré (RAG), validation humaine obligatoire avant toute action de remédiation.

6.7 Module Dashboard

Interface de supervision destinée à l'analyste SOC, cohérente avec votre expérience de développement de portail d'administration SaaS multi-tenant.

- Frontend applicatif (gestion des cas, alertes, chat GenAI) : Blazor (.NET) — capitalise sur l'expérience du projet OnePick.
- Visualisation temps réel (métriques, graphes de tendance) : panneaux Grafana embarqués + Kibana pour l'exploration des logs.
- Carte des attaques (géolocalisation IP source) : composant Leaflet.js intégré à la page Blazor.
- Communication temps réel (push d'alertes) : SignalR (.NET).
- KPIs suivis : nombre d'alertes/jour, répartition par sévérité, MTTD (temps moyen de détection), MTTR (temps moyen de réponse), taux de faux positifs.

7. Architecture technique et stack technologique globale

Couche	Technologies retenues
Collecte / agents	Filebeat, Winlogbeat, Wazuh agent, Suricata
Bus de messages	Kafka ou Redis Streams
Stockage événements	Elasticsearch (logs), PostgreSQL (alertes / métadonnées), Redis (cache)
IA / Machine Learning	Python, scikit-learn, XGBoost, PyTorch/TensorFlow, SHAP, LIME, imbalanced-learn
Vision (malware-as-image)	OpenCV, Pillow
Threat Intelligence	mitreattack-python, API NVD, STIX/TAXII
GenAI / RAG	API LLM (Claude/OpenAI), ChromaDB ou FAISS, sentence-transformers
Backend API	.NET Core Web API (+ SignalR) et/ou FastAPI (Python)
Frontend	Blazor (.NET), Grafana, Kibana, Leaflet.js
Base de données relationnelle	PostgreSQL / Oracle PL/SQL (option entreprise)
Conteneurisation & orchestration	Docker, Docker Compose (dev), Kubernetes (prod)

Couche	Technologies retenues
CI/CD	GitHub Actions (build, tests, scan sécurité, déploiement)
Cloud	AWS (EC2, ECS Fargate, S3, RDS, IAM)
Supervision infrastructure	Prometheus (métriques), Grafana (visualisation), Alertmanager

8. Jeux de données et ressources IA

- CICIDS2017 / CICIDS2018 (Université de Nouveau-Brunswick) — trafic réseau étiqueté multi-attaques.
- NSL-KDD et UNSW-NB15 — détection d'intrusion réseau classique, benchmark académique.
- LogHub — logs systèmes réels anonymisés (Linux, Hadoop, etc.) pour l'entraînement de la normalisation.
- CTU-13 — trafic de botnet pour la détection comportementale.
- EMBER / Maling — datasets de malware pour la classification par représentation binaire/image.
- MITRE ATT&CK Enterprise Matrix (STIX 2.1) et NVD Data Feeds — bases de threat intelligence publiques.

9. Sécurité, éthique et gouvernance des données

- Aucune donnée réelle de l'UM6P n'est collectée, stockée ou analysée : environnement isolé et jeux de données publics uniquement.
- Anonymisation systématique de toute donnée simulée pouvant être assimilée à une donnée personnelle, conformément à la loi marocaine 09-08 et aux principes du RGPD.
- Contrôle d'accès basé sur les rôles (RBAC) pour le dashboard : analyste, superviseur, administrateur.
- Journalisation des actions effectuées par le GenAI Assistant (traçabilité, audit).
- Toute action de remédiation proposée par l'IA reste soumise à validation humaine — aucune remédiation automatique en autonomie complète.

10. Livrables attendus

- Cahier des charges détaillé et architecture technique documentée (le présent document).
- Code source versionné (dépôt Git structuré par module).
- Environnement de laboratoire reproductible (docker-compose.yml + scripts de génération de trafic simulé).
- Modèles IA entraînés, accompagnés d'un rapport de performance (précision, rappel, F1, matrice de confusion).
- Dashboard fonctionnel déployé (Blazor + Grafana) avec données de démonstration.
- Assistant GenAI SOC opérationnel avec base documentaire indexée.
- Pipeline CI/CD fonctionnel (GitHub Actions) et manifestes Kubernetes.
- Rapport final et support de maintenance.

11. Planning prévisionnel (exemple sur 10 semaines)

Phase	Semaines	Contenu
1. Cadrage & environnement	S1 – S2	Cahier des charges, mise en place du lab (Docker), collecte des datasets
2. Pipeline de collecte	S3	Agents Filebeat/Winlogbeat/Suricata, normalisation ECS, stockage Elasticsearch
3. Modèles de détection IA	S4 – S5	Entraînement XGBoost / CNN malware, évaluation, gestion du déséquilibre

Phase	Semaines	Contenu
4. Scoring, XAI & Threat Intel	S6	Module de scoring, intégration SHAP, connexion MITRE ATT&CK / NVD
5. GenAI SOC Assistant	S7	Indexation RAG, intégration API LLM, tests des cas d'usage
6. Dashboard & API backend	S8	Développement Blazor, API .NET/FastAPI, intégration Grafana/Kibana
7. DevOps & déploiement	S9	Dockerisation complète, CI/CD GitHub Actions, déploiement AWS/Kubernetes
8. Tests, documentation, soutenance	S10	Tests end-to-end, rédaction du rapport final, préparation de la démo

12. Critères de réussite / KPIs du projet

- Précision (precision) et rappel (recall) des modèles de détection ≥ 90 % sur les classes majoritaires, ≥ 75 % sur les classes minoritaires (insider threat, ransomware).
- Temps de traitement d'un événement (ingestion → alerte) inférieur à quelques secondes en environnement de démonstration.
- Disponibilité du dashboard ≥ 99 % pendant la phase de démonstration.
- Pertinence perçue des réponses du GenAI Assistant, évaluée qualitativement par un panel d'analystes/encadrants.
- Couverture fonctionnelle : les 5 familles d'attaques ciblées sont détectées et correctement classifiées en environnement de test.

13. Risques et limites identifiés

Risque	Mitigation
Déséquilibre des classes dans les datasets publics	Rééchantillonnage (SMOTE), pondération des classes, métriques adaptées (F1, AUC-PR)
Hallucination du LLM dans le GenAI Assistant	Architecture RAG stricte, citation des sources, garde-fous de validation humaine
Complexité d'intégration multi-technologies (.NET, Python, ELK, AWS)	Architecture en micro-services découplés communiquant par API/REST
Délai limité du stage/projet (10 semaines)	Priorisation MVP : détection + dashboard d'abord, GenAI et threat intel en itération 2
Représentativité limitée des datasets publics vs. trafic réel	Documentation explicite des limites, architecture prête pour connexion à des flux réels ultérieurement

14. Glossaire (extrait)

- SOC : Security Operations Center — centre opérationnel de sécurité.
- XAI : Explainable AI — intelligence artificielle explicable.
- RAG : Retrieval-Augmented Generation — génération augmentée par recherche documentaire.
- MTTD / MTTR : Mean Time To Detect / Respond — temps moyen de détection / de réponse à un incident.
- UEBA : User and Entity Behavior Analytics — analyse comportementale des utilisateurs et entités.
- ECS : Elastic Common Schema — schéma standard de normalisation des logs.